Bloque 2: Ecosistema OWASP y Protección Proactiva

FADENA

OWASP y Protección Proactiva

Ing. Roxana Quiroga Sollinger

OWASP

Módulo 3: OWASP y Protección Proactiva

FADENA

3.1 OWASP

3.2 OWASP TOP 10

3.3 Protección Proactiva

3.4 Defensa en Profundidad



3.1 OWASP

Definición

https://owasp.org/

> *El Proyecto Abierto Mundial de Seguridad de Aplicaciones (OWASP, Open Worldwide Application Security Project, por sus siglas en inglés) es una comunidad abierta dedicada a capacitar a las organizaciones para desarrollar, adquirir y mantener aplicaciones y API en las que se pueda confiar.*



FADENA

3.1 OWASP

Contribuciones OWASP

Seguridad Web y APIs

Riesgos: Vulnerabilidades en aplicaciones tradicionales y comunicación entre servicios (exposición de datos en endpoints, falta de límites de tasa, inyecciones y fallos de autenticación).
Proyectos: OWASP Top 10 (Web), API Security Top 10, ASVS (Estándar de Verificación de Seguridad en Aplicaciones).

AI/LLM

Riesgos: Inyección de prompts, envenenamiento de datos de entrenamiento, exfiltración de modelos y ejecución de código no confiable a través de agentes de IA.
Proyectos: Top 10 for LLM Applications, OWASP AI Exchange.

Infraestructura en la Nube, Contenedores y Serverless

Riesgos: Configuraciones defectuosas en entornos cloud, permisos excesivos en funciones sin servidor y aislamiento deficiente en orquestadores de contenedores.
Proyectos: Kubernetes Top 10, Serverless Top 10, Cloud-Native Security.

Entornos Móviles, IoT y Dispositivos Embebidos

Riesgos: Almacenamiento inseguro en el dispositivo, ingeniería inversa, canales de comunicación no cifrados y firmware vulnerable en hardware conectado.
Proyectos clave: Mobile Top 10, MASVS (Estándar de Verificación Móvil), IoT Top 10.

DevSecOps

Riesgos: Uso de librerías de terceros con vulnerabilidades conocidas, manipulación de repositorios o pipelines CI/CD y falta de visibilidad sobre los componentes del software.
Proyectos: Dependency-Check, CycloneDX (SBOM), SCVS (Verificación de Componentes) y SAMM (Modelo de Madurez de Seguridad).

Privacidad y Modelado de Amenazas

Riesgos: Recolección excesiva o indebida de datos personales y fallos estructurales no identificados durante la fase de diseño.
Proyectos: OWASP Privacy Risks Top 10, Threat Modeling Project.

FADENA

3.1 OWASP

Riesgos de Seguridad Web y APIs (Application Platform Integration)

Exposición de datos en endpoints

Llamada en inglés Excessive Data Exposure. Ocurre cuando la respuesta de una API devuelve más información de la que la interfaz o el cliente necesitan, confiando de forma insegura en que la aplicación frontal (web o móvil) filtrará los datos sobrantes antes de mostralos.

Falta de límites de tasa

Llamada en inglés Unrestricted Rate Limiting. una vulnerabilidad que ocurre cuando una aplicación o API no controla ni restringe la cantidad de solicitudes que un mismo cliente o dirección IP puede realizar en un intervalo de tiempo determinado.



Inyecciones

Es un fallo de seguridad que ocurre cuando se envía información no confiable a un intérprete o motor de ejecución como parte de un comando o consulta, haciendo que la aplicación interprete los datos del usuario como código ejecutable

Fallos de autenticación

Son vulnerabilidades en los mecanismos de un sistema para confirmar la identidad de un usuario, servicio o proceso, lo que permite a un atacante suplantar identidades legítimas o asumir el control de cuentas.

FADENA

3.1 OWASP

Riesgos en entornos Móviles, IoT y dispositivos embebidos

Almacenamiento inseguro en el dispositivo

Insecure Data Storage es una vulnerabilidad que ocurre cuando una aplicación móvil, dispositivo IoT o sistema embebido guarda información sensible en la memoria local sin el cifrado adecuado o en ubicaciones con permisos mal configurados.

Ingeniería inversa

Reverse Engineering es la técnica mediante la cual un atacante descompila, deconstruye y analiza el código ejecutable (archivos APK, IPA, binarios) o el firmware de un dispositivo para comprender su arquitectura interna, lógica de negocio y secretos



Firmware vulnerable en hardware conectado

Ocurre cuando los dispositivos IoT o embebidos ejecutan software base desactualizado, defectuoso o con fallos de seguridad conocidos, exponiendo al dispositivo (y a la red a la que se conecta) a accesos no autorizados o control remoto.

Canales de comunicación no cifrados

Insecure Communication representan una vulnerabilidad que ocurre cuando los datos transmitidos entre una aplicación móvil, un dispositivo IoT o sistema embebido y su servidor backend (o entre dispositivos) viajan a través de la red en texto plano o utilizando protocolos criptográficos débiles o mal configurados.

FADENA

3.1 OWASP

Riesgos en Inteligencia Artificial (AI) y Modelos de Lenguaje (LLM)

Inyección de prompts

Es una vulnerabilidad que ocurre cuando un atacante manipula las entradas de texto enviadas a un modelo de lenguaje para alterar su comportamiento previsto, haciendo que el modelo ignore sus instrucciones originales, se salte las barreras de seguridad o ejecute acciones no autorizadas.

Envenenamiento de datos de entrenamiento

Ocurre cuando un atacante manipula o corrompe la información utilizada para entrenar, afinar (fine-tuning) o alimentar un modelo de IA, introduciendo vulnerabilidades, sesgos deliberados o puertas traseras (backdoors).



Ejecución de código no confiable a través de agentes de IA

Es una vulnerabilidad que ocurre cuando a un sistema o agente basado en un LLM se le otorga la capacidad de generar y ejecutar código fuente (como Python, Bash o JavaScript) de forma autónoma, pero carece de un entorno de aislamiento seguro (sandbox) o de validación de las instrucciones ejecutadas.

Exfiltración de modelos

Es el acceso, copia o extracción no autorizada de un modelo de inteligencia artificial propietario, incluyendo sus pesos (weights), arquitectura, hiperparámetros o el código de entrenamiento. Representa el robo directo del activo digital más valioso de una organización de IA.

FADENA

3.1 OWASP

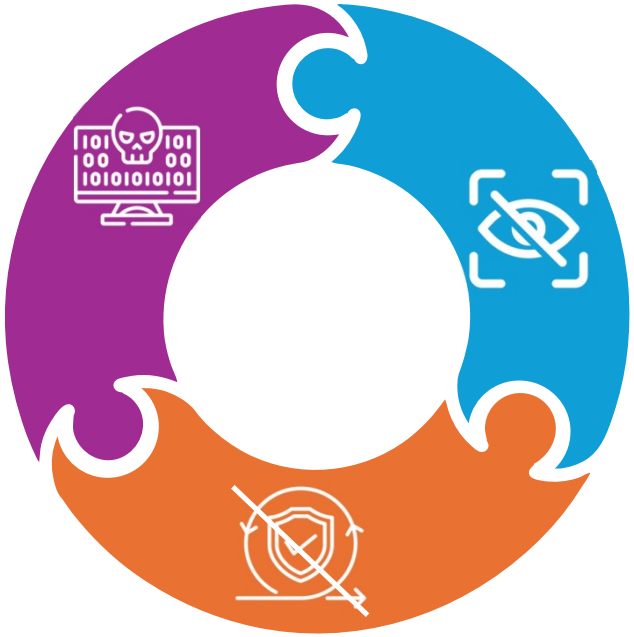
Riesgos en DevSecOps

Uso de librerías de terceros con vulnerabilidades conocidas

Ocurre cuando un proyecto integra módulos, paquetes de código abierto o frameworks que contienen fallos de seguridad públicos (CVEs) que no han sido actualizados o parcheados.

Manipulación de repositorios o pipelines CI/CD

Es el compromiso o alteración no autorizada de los sistemas de control de versiones (Git) o de los servidores de automatización (GitHub Actions, GitLab CI, Jenkins) para inyectar código malicioso, robar secretos o alterar los paquetes de software antes de que lleguen a producción.



Falta de visibilidad sobre los componentes del software

Ocurre cuando una organización desconoce la totalidad de librerías, dependencias transitivas, paquetes de código abierto y módulos de terceros que conforman sus aplicaciones.

FADENA

3.1 OWASP

Riesgos en Infraestructura en la Nube, Contenedores y Serverless

Configuraciones defectuosas en entornos cloud

Cloud Security Misconfiguration son fallos en los ajustes de seguridad, políticas o permisos de la infraestructura en la nube que dejan expuestos recursos, servicios o datos a accesos no autorizados. A diferencia de las vulnerabilidades en el código, este riesgo surge por errores humanos en la administración o por dependencia de proveedores en la nube.

Permisos excesivos en funciones sin servidor

Llamada en inglés Over-privileged Serverless Functions. ocurren cuando una función cloud cuenta con un rol de ejecución con privilegios, acciones o alcance de recursos más amplios que los estrictamente necesarios para cumplir su tarea



Aislamiento deficiente en orquestadores de contenedores.

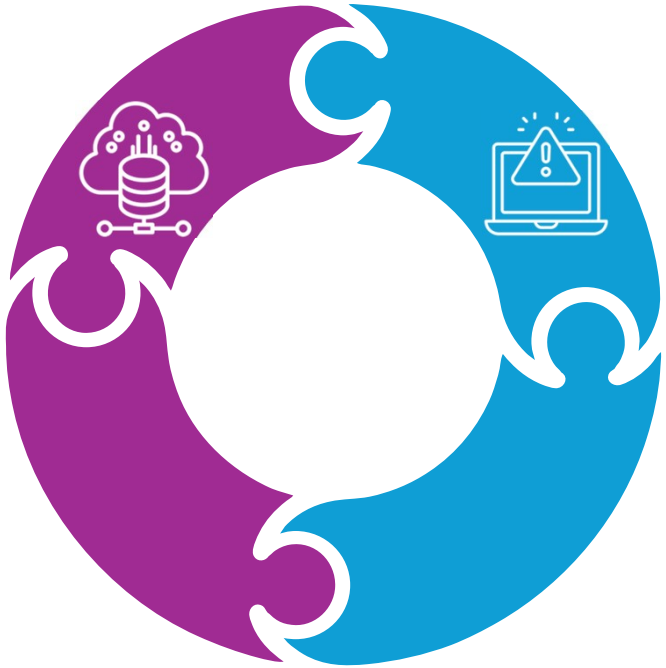
Ocurre cuando las cargas de trabajo (pods o contenedores) no están debidamente confinadas entre sí ni respecto al nodo subyacente que las aloja, permitiendo que el compromiso de un solo contenedor ponga en riesgo todo el clúster.

3.1 OWASP

Riesgos en Privacidad y Modelado de Amenazas

Recolección excesiva o indebida de datos personales

Data Minimization Failure ocurre cuando una aplicación o sistema recopila, procesa o almacena más Datos de Identificación Personal (PII) de los estrictamente necesarios para cumplir con la función o propósito explícito del servicio.



Fallos estructurales no identificados durante la fase de diseño

Insecure Design o fallas arquitectónicas son deficiencias lógicas o de arquitectura en la concepción del sistema que se introducen antes de escribir una sola línea de código y pasan desapercibidas por no realizar un análisis de riesgos o modelado de amenazas previo.